

Web-Security und Intrusion Prevention

SoSe 26

Prof. R. Zahoransky

Hochschule Furtwangen (University of Applied Science)

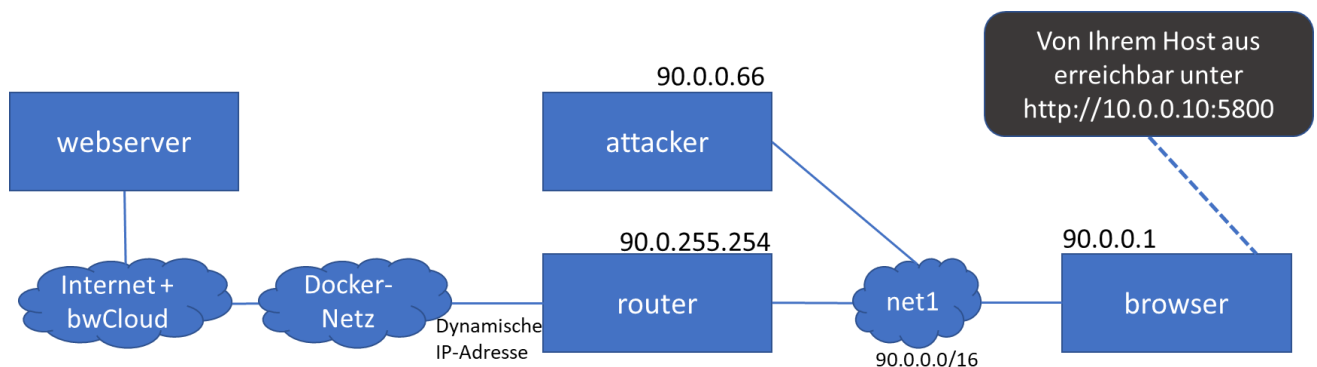
Aufgabenblatt 8 HTTPs mit Zertifikaten und MITM-Angriffe

Lernziele: Zertifikatserstellung mit Let's Encrypt und Durchführung eines Man-in-the-Middle Angriffs

Abgabetermin wird bekannt gegeben

Aufgabe 1: Verstehen der Anwendungen

In der Aufgabe werden Sie mehrere Docker-Container starten und eine Webseite auf bwCloud hosten.



- **Browser:** Dies ist das Zielsystem, dass Sie angreifen werden.
- **Router:** Der Container, der die Internet-Verbindung herstellt
- **Attacker:** Dieser Container stellt den Angreifer dar. Hierauf werden Sie den MITM-Angriff durchführen
- **Webserver:** In der bwCloud werden Sie einen Webserver installieren, den Sie über HTTPs mit gültigen Let's Encrypt Zertifikaten anbinden.

Aufgabe 2: Starten Sie eine VM und hosten Sie eine Webanwendung

Nun wird die Umgebung für die Aufgabe eingerichtet

SSH-Schlüssel für den Zugriff auf den VM generieren

SSH-Passwörter sind unsicher, da sie leicht angreifbar sind. Daher ist die SSH-Authentifizierung über Passwörter auf den bwCloud-VMs deaktiviert. Sie müssen die Authentifizierung über SSH-Schlüssel nutzen. Falls Sie noch keinen SSH-Schlüssel haben, erzeugen Sie sich einen mit dem Befehl `ssh-keygen`. Folgen Sie den Anweisungen. Sichern Sie Ihren SSH-Schlüssel mit einem Passwort ab.

Sie finden Ihre SSH-Schlüssel unter `~/ssh/` darin sind zwei Dateien:

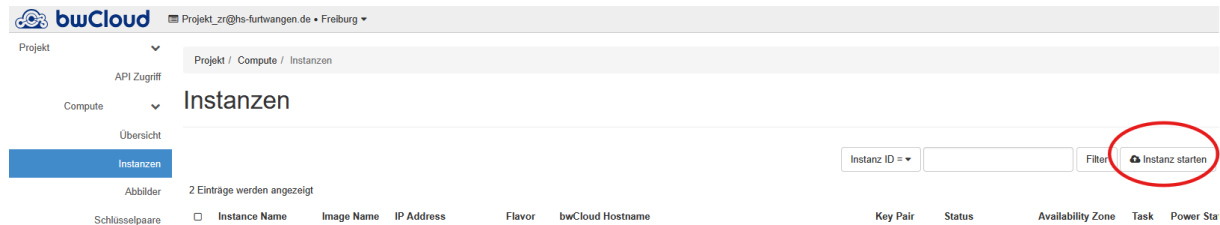
- **id_rsa** ist ihr **privater** Schlüssel. Geben Sie diese Datei oder dessen Inhalt nie in fremde Hände.
- **id_rsa.pub** ist der **öffentliche** Schlüssel. Diesen Schlüssel kopieren Sie auf alle SSH-Hosts, mit denen Sie sich verbinden möchten

Erstellen Sie eine neue VM auf bwCloud:

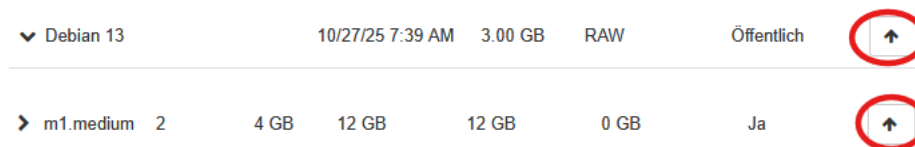
Gehen Sie auf das Dashboard von bwCloud und loggen Sie sich mit Ihrem HFU-Account ein:

<https://portal.bw-cloud.org/>

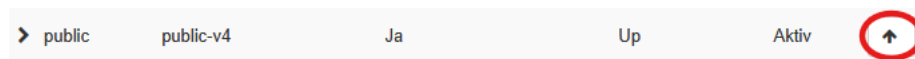
Erstellen Sie eine neue VM:



Wählen Sie Debian 13 und m1.medium aus

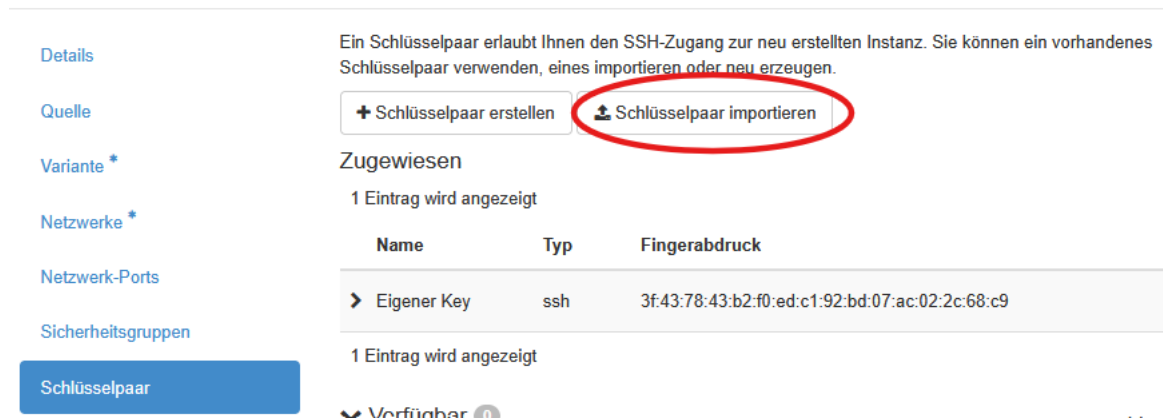


Als Netzwerkverbindung wählen Sie public-v4:

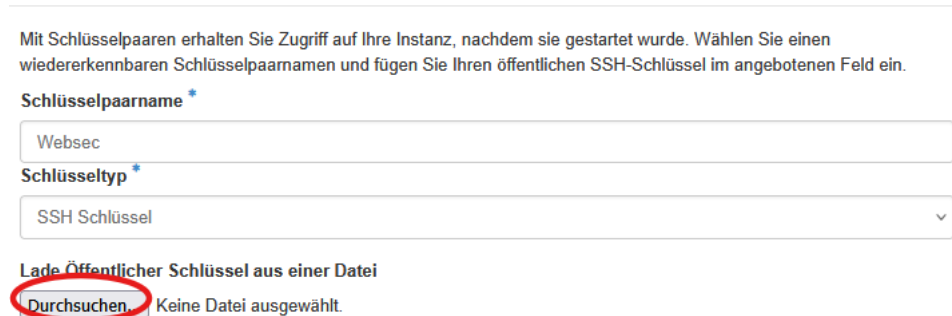


Klicken Sie auf weiter, bis Sie das Schlüsselpaar hochladen können.

Instanz starten



Schlüsselpaar importieren



Wählen Sie die Datei id_rsa.pub aus dem Verzeichnis .ssh in Ihrem Home-Verzeichnis aus (Windows: C:\Users\

Das Fenster sollte sich mit dem Inhalt der Datei füllen. Klicken Sie auf Schlüsselpaar importieren.

▼ Verfügbar ¹ Eines auswählen

🔍 Klicken Sie hier für Filter oder zur Volltextsuche. ✕

1 Eintrag wird angezeigt

Name	Typ	Fingerabdruck
➤ Websec	ssh	be:ea:8d:07:4f:13:19:aa:60:56:e7:1a:8c:d8:20:d1

1 Eintrag wird angezeigt

Verbinden Sie sich mit der VM und installieren Sie die Abhängigkeiten

Starten Sie nun die VM. Es dauert kurz, dann ist die VM gestartet. Loggen Sie sich mit SSH unter der angezeigten IP-Adresse der VM ein. Der Benutzername lautet **debian**:

☐	Instance Name	Image Name	IP Address	Flavor	bwCloud Hostname	Key Pair	Status
☐	Web-Sec Test	Debian 13	192.52.37.109	m1.medium	abcfcea9-d516-48d6-aa4b-eb871bab1f13.fr.bw-cloud-instance.org	Websec	Aktiv

Hier: `ssh debian@192.52.37.109` (dies ist eine öffentlich geroutete IP-Adresse).

Installieren Sie zuerst alle Updates: `sudo apt update && sudo apt upgrade -y`. Sollte apt wegen Konflikten bei Konfigurationsdateien nachfragen, behalten Sie die existierenden Dateien bei.

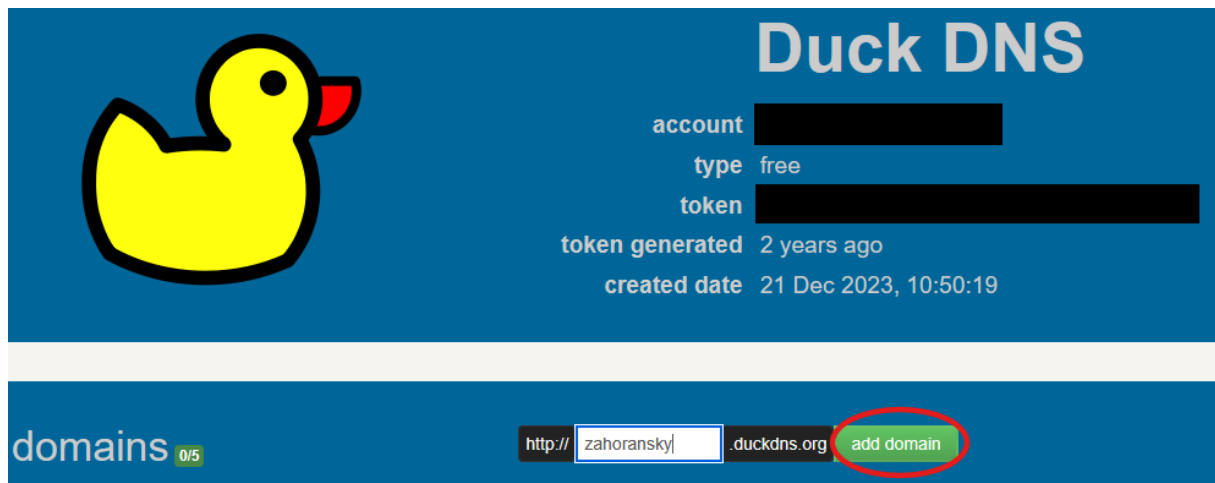
Installieren Sie danach docker: `sudo apt install docker.io docker-compose`

Fügen Sie den Benutzer *debian* zur Gruppe docker hinzu, damit docker-Befehle ohne root-Rechte genutzt werden können: `sudo adduser debian docker`

Sie müssen danach die SSH-Verbindungen mit „exit“ trennen und sich erneut verbinden, damit die Gruppenzugehörigkeiten neu ausgewertet werden.

Vergeben Sie der VM einen Domainnamen

Die VM soll unter einem Domainnamen erreichbar sein. Sie können hierfür [duckdns.org](https://www.duckdns.org) benutzen. Navigieren Sie auf www.duckdns.org. Erstellen Sie sich einen Account und wählen Sie einen Domainnamen aus (der auf .duckdns.org enden wird):



Duck DNS

account

type free

token

token generated 2 years ago

created date 21 Dec 2023, 10:50:19

domains 0/5

http:// .duckdns.org

Es wäre möglich einen Dienst einzurichten, der die IP-Adresse für diesen DNS-Eintrag automatisch setzt. Da sich die IP-Adressen der VMs nicht ändern, genügt es die IP-Adresse manuell zu setzen:

domain	current ip	ipv6	changed
zahoransky	192.52.37.109 update ip	ipv6 address update ipv6	0 seconds ago

Ihre VM ist nun unter der Domäne erreichbar.

Installieren Sie eine Webanwendung

Als Beispiel-Anwendung werden wir **Immich** benutzen, eine freie Bildverwaltung. Folgen Sie den Anweisungen unter <https://docs.immich.app/install/docker-compose/>

Ändern Sie die Datei docker-compose.yml ab, sodass für die Kommunikation nach außen Port 80 genutzt wird:

```
ports:|
- '80:2283'
```

Starten Sie immich mit `docker compose up -d`

Machen Sie einen ersten Test und erstellen Sie sich einen Benutzer, indem Sie in Ihrem Browser auf Ihre neue Domäne navigieren.

Geben Sie nur pseudonyme, ein temporäres Passwort und eine nicht existierende E-Mailadresse ein! Die Verbindung ist unverschlüsselt und wird mitgelesen.

Aufgabe 3: Führen Sie einen MITM-Angriff durch

Entpacken Sie den gesamten Inhalt der ZIP-Datei der Aufgabe und starten Sie die docker-compose Datei:

- `docker compose build`
- `docker compose up`

Es sind nun drei Container aktiv: Browser, Attacker und Router. Der Container Browser ist über den Container Router über Ihren PC mit dem Internet verbunden. Browser stellt eine VNC-Verbindung bereit, die auch über eine Web-Implementierung erreichbar ist: Gehen Sie auf <http://10.0.0.10:5800/>. Sie sollten den Firefox-Browser sehen. Dieser Browser ist das Opfer, dass Sie gleich angreifen.

Führen Sie ein ARP-Spoofing durch, um sich als Default-Gateway auszugeben

- Mit `docker exec -it attacker bash` verbinden Sie sich mit der Konsole des Containers attacker.
- Der Container ist zwar mit dem Netzwerk verbunden, die Routen sind aber noch nicht gesetzt. Nutzen Sie `route add`, um den Router 90.0.255.254 als Default-Gateway zu nutzen. Ihr Angriff würde sonst die Internet-Verbindung des Opfers unterbrechen

- Nutzen Sie das Tool arpsoof, um sich gegenüber 90.0.0.1 als 90.0.255.254 und gegenüber 90.0.255.254 als 90.0.0.1 auszugeben. Unter <https://man.archlinux.org/man/extra/dsniff/arpsoof.8.en> finden Sie einen Hinweis auf die Nutzung des Tools.
- Mit tcpdump können Sie sich die an- und abgehenden Pakete anzeigen lassen. Suchen Sie im Internet, welche Parameter notwendig sind, um sich die Paketinhalte anzeigen zu lassen.

Lesen Sie das eingegebene Passwort aus

- Als Opfer: Loggen Sie sich nun auf Ihrer Webseite in der bwCloud ein
- Zeigen Sie einen Screenshot des übertragenen Passworts
- Beenden Sie tcpdump und arpsoof

Aufgabe 4: Mit Verschlüsselung und Zertifikaten gegen den Angriff schützen

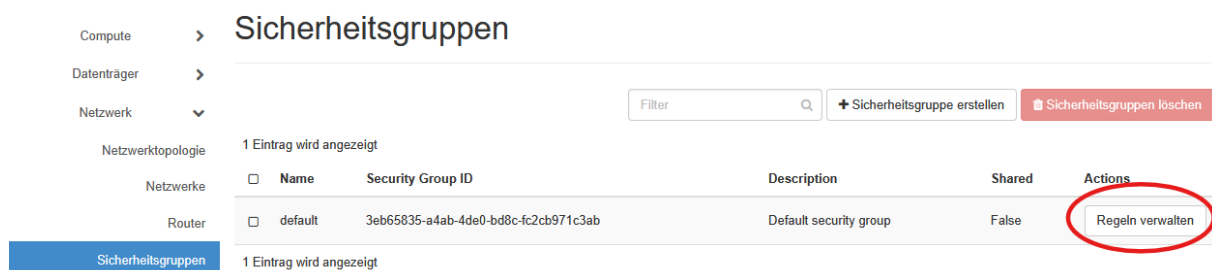
In diesem Schritt sichern wir die Webseite mit Zertifikaten sichern und die Übertragung verschlüsseln. Als Vorbereitung Beenden Sie Immich auf Ihrer bwCloud-VM. Gehen Sie in das Verzeichnis, in welchem die docker-compose Datei von Immich gespeichert ist. Geben Sie `docker-compose down` ein.

Ändern Sie in der Datei `docker-compose.yml` den Port wieder auf 2283, damit Immich nicht mehr direkt, sondern nur noch über den Proxy erreichbar ist.

Auf der bwCloud VM: Starten Sie den NginX Proxy Manager (NPM). Geben Sie hierfür ohne Zeilenumbruch ein:

```
docker run -p80:80 -p81:81 -p443:443 -v letsencrypt:/etc/letsencrypt
jc21/nginx-proxy-manager:latest
```

Sie müssen Port 81/TCP in der bwCloud-Firewall freigeben, damit Sie auf die Konfiguration von NPM zugreifen können:



Klicken Sie auf Regel hinzufügen

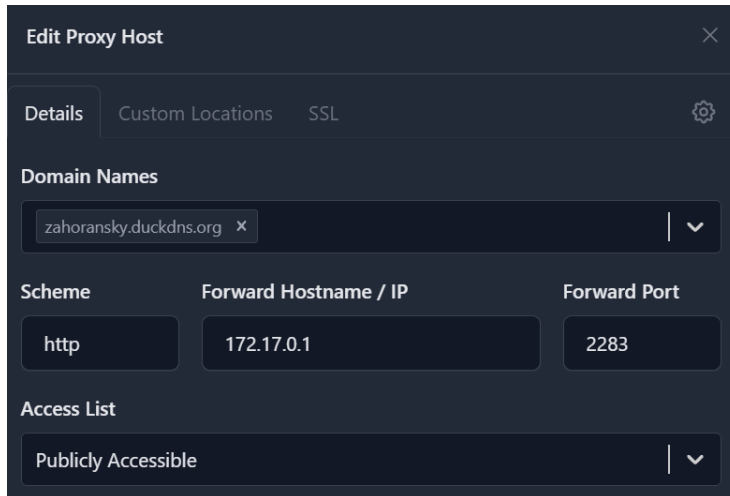
Tragen Sie Port 81/TCP als erlaubten Port für **eingehenden** und **ausgehenden** Datenverkehr ein.

Navigieren Sie mit Ihrem eigenen Browser auf Ihre bwCloud VM, Port 81. Sie sehen die Startseite von NPM. Erstellen Sie sich auch hier temporäre Benutzernamen und Passwörter, da die Verbindung unsichert ist!

- Vorbereitung: Der neu gestartete Container ist über ein neues (virtuelles) Netzwerk mit dem Namen `docker0` verbunden. Finden Sie mit `ip a s` die IP-Adresse Ihres PCs auf diesem Netzwerk heraus.

Klicken Sie auf Proxy Hosts -> Add Proxy Host

- Tragen Sie Ihre Domain ein und wählen Sie als Proxy-Ziel den Port 2283 auf der IP-Adresse Ihres PCs (im docker0) Netzwerk:



Edit Proxy Host

Details Custom Locations SSL

Domain Names

zahoransky.duckdns.org

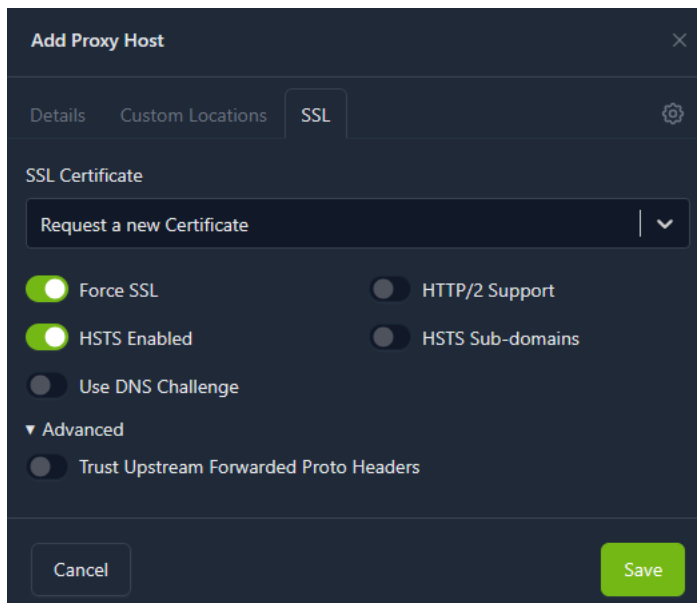
Scheme Forward Hostname / IP Forward Port

http 172.17.0.1 2283

Access List

Publicly Accessible

- Unter dem Reiter **SSL**: Wählen Sie „Request a new Certificate“. Damit wird NPM bei Let's Encrypt ein Zertifikat erstellen und automatisch eintragen.
- Aktivieren Sie außerdem die Schalter für Force SSL und HSTS Enabled:



Add Proxy Host

Details Custom Locations SSL

SSL Certificate

Request a new Certificate

☒ Force SSL ☐ HTTP/2 Support

☒ HSTS Enabled ☐ HSTS Sub-domains

☐ Use DNS Challenge

▼ Advanced

☐ Trust Upstream Forwarded Proto Headers

Cancel Save

- Suchen und erläutern Sie die Bedeutung von HSTS
- Klicken Sie auf Save. Es wird eine Zeit dauern, bis NPM das Zertifikat erhält. Danach wird sich das Fenster schließen.
- Lesen Sie im Internet nach und erläutern Sie, wie Let's Encrypt sicherstellt, dass Sie im Besitz des Webserver sind und nicht ein Angreifer sind.

Nun ist Ihr Proxy eingerichtet. Er wird über Port 80 und 443 mit der Außenwelt kommunizieren und HTTPSs verschlüsselte Verbindungen über das gerade erstellte Zertifikat aufbauen. Intern kommuniziert NPM mit Immich über das Netzwerk docker0 mit Ihrer VM auf Port 2283, um den tatsächlichen Inhalt auszuliefern.

- Starten Sie wieder Immich: `docker compose up -d`

- Navigieren Sie auf <https://<Ihre-Domaine>.duckdns.org>
- Nun sollte der Browser eine HTTPS-verschlüsselte Verbindung aufbauen
- Führen Sie den MITM-Angriff erneut durch. Können Sie das Passwort noch auslesen?